

AI adoption lifecycle별 Responsibility·Accountability 운영모델

Production 관점에서는 lifecycle마다 수행 책임(Responsibility)과 최종 설명·의사결정 책임(Accountability)은 분리해야 해.

- **Development Review:** 설계와 구현이 요구사항에 맞는지 검토
- **QE/TEVV:** 품질·안전·control effectiveness를 독립적으로 시험
- **AI GRC:** 위험 분류, 통제 기준, residual risk 및 예외 처리 검토
- **Audit:** 프로세스와 통제가 실제로 준수되었는지 사후 독립 검증

제안: AI adoption lifecycle별 Responsibility·Accountability 운영모델

Microsoft Responsible AI Standard v2는 Impact Assessment, reviewer approval, Responsible Release Criteria, pre-release/ongoing evaluation 및 gap management 요구사항을 제시한다.

다만 lifecycle별 상세 RACI와 Development·QE/TEVV·AI GRC·Internal Audit의 역할 배정은 규정하지 않는다.

아래 표의 조직 및 역할 구조는 해당 요구사항을 production 환경에서 운영하기 위해 재구성한 **Proposed Operating Model**이다.

Lifecycle	Responsible — 수행 책임	Accountable — 최종 책임	Review·QE·Audit	출처 구분 및 근거
AI use case 식별	Product Owner, Business Owner	Business Owner	AI GRC가 intended use와 stakeholder 식별 결과 검토	MS Standard 기반 재구성 — A1.1, A3.1, A3.2는 개발 초기 Impact Assessment와 intended use·입출력·환경 문서화를 요구. 구체적 역할 배정은 제안
Impact Assessment	Product, AI/ML, Security, Privacy 담당자	Business Owner 또는 AI System Owner	AI GRC가 assessment 완전성과 risk classification 검토	MS Standard — A1.1은 초기 Impact Assessment 수행, A1.2는 지정 reviewer 검토와 승인, A1.3은 정기·변경 시 갱신 요구
Sensitive-Restricted Use 분류	AI GRC, Legal, Privacy, Security	Responsible AI Approver	고위험 use case는 Review Board 검토	MS Standard — A2.1~A2.3은 Restricted Use 및 Sensitive Use 식별·보고·정기 재검토 요구. 담당 조직명은 제안
Responsible Release Criteria 정의	개발, QE, Security, AI GRC	AI System Owner	QE가 측정 가능성, AI GRC가 위험 coverage 검토	MS Standard — A3.3, A5.5 및 각 월치별 요구사항에서 metric/error type·Responsible Release Criteria 정의 요구. 역할 배정은 제안
Pre-release Evaluation	QE/TEVV, Security Testing	QE 또는 Validation 책임자	개발팀과 분리된 평가자가 성능·안전·보안·통제 효과성 검증	MS Standard 기반 해석 — A3.4~A3.5는 evaluation plan, pre-release evaluation과 ongoing evaluation 주기 문서화를 요구. 독립 QE 조직 지정은 제안
Reviewer 승인	지정 Reviewer	Release Approver 또는 Risk Owner	AI GRC·Security·Privacy가 분야별 검토 또는 sign-off	MS Standard — A1.2는 지정 reviewer의 검토와 필수 승인 확보 요구. Release Approver·Risk Owner 구조는 제안
Deployment	Platform, MLOps, DevOps, 운영팀	Service/System Owner	Change Management와 Security가 승인된 configuration 확인	Proposed Operating Model — MS Standard에 이와 같은 배포 RACI는 없음. A5.1의 배포 중·배포 후 운영·감독 stakeholder 식별 요구를 production 구조도 확장
Ongoing Monitoring	운영팀, MLOps, SOC, Model Monitoring	Service/System Owner	QE가 주기적 평가, AI GRC가 KRI와 control 상태 검토	MS Standard 기반 재구성 — A3.5 및 각 Goal의 Ongoing Evaluation Checkpoint는 평가 주기 정의를 요구. 구체적인 monitoring 조직과 KRI 운영은 제안
Gap Management	개발, 데이터, 보안 또는 운영 담당자	Control Owner 또는 System Owner	AI GRC가 remediation-residual risk·기한 추적	MS Standard + 제안 — A5.7, T1.6 등은 release criteria 미충족 시 reviewer와 협의하여 gap management plan을 문서화하도록 요구. Control Owner와 escalation workflow는 제안
재평가·종단	Product, 운영, 개발, QE	Business Owner 또는 Risk Owner	Review Board가 재승인 또는 종단 결정	MS Standard 기반 재구성 — A1.3은 연례·새 intended use·release stage 변경 시 재평가 요구. A3.7은 근거가 부족하거나 반증되면 gap 해소 또는 system 종단을 요구. 의사결정 역할은 제안
Lifecycle 전체 Audit	Internal Audit 또는 Independent Assurance	Audit 책임자	프로세스 준수와 control evidence를 독립 검증	Proposed Operating Model — MS Standard v2 General Requirements에 lifecycle 전체 Internal Audit RACI는 명시되지 않음

출처 표기 기준

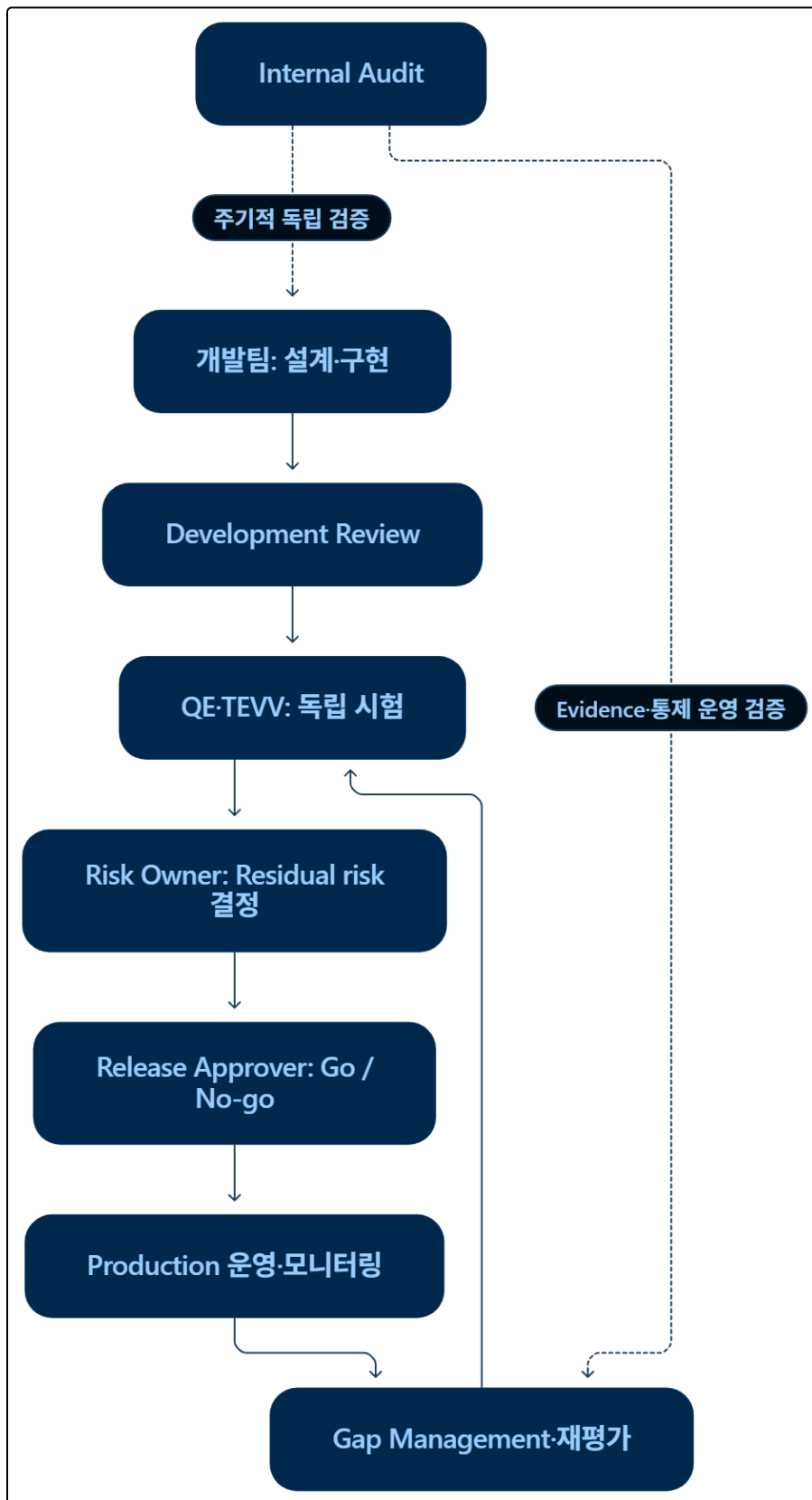
표기	의미
MS Standard	Microsoft 문서에 요구사항이 직접 명시됨
MS Standard 기반 해석·재구성	원문 요구사항을 lifecycle 운영 단계로 재배치한 내용
Proposed Operating Model	Development·QE·GRC·Audit 역할 및 Accountability를 실제 조직 운영에 맞게 제안한 내용

역할별 핵심 Accountability

역할	Accountability
Business Owner	AI use case의 필요성, 편익, intended use 및 사업상 위험

AI System Owner	AI system이 승인된 요구사항과 control은 충족하도록 운영
Development Owner	설계·코드·모델 통합 및 기술적 remediation
QE/TEVW Owner	평가 방법의 적절성과 시험 결과의 신뢰성
Control Owner	특정 control의 설계, 구현 상태 및 효과성
Risk Owner	Residual risk의 수용·완화·회피·이전 결정
Release Approver	release criteria와 evidence를 근거로 한 Go/No-go 결정
AI GRC	기준·분류·oversight-gap escalation 체계의 운영
Internal Audit	governance와 control이 설계된 대로 작동하는지 독립적으로 보증

Development Review, QE, Audit의 위치



제안: 실제 애자일 역할 기반 운영모델

일반적인 애자일/Scrum 조직에는 **Control Owner, Risk Owner, Release Approver**가 Scrum 역할로 존재하지 않아.

Scrum의 공식 Accountabilities는 다음 세 가지뿐이야.

- **Product Owner**
- **Developers**
- **Scrum Master**

따라서 실제 애자일 조직에 맞추려면 기존 역할에 책임을 배정하고, 중요한 위험만 외부 조직에 escalation하는 편이 현실적이야.

결론적으로 문서에는 **Control OwnerRisk Owner**를 애자일 기본 역할로 넣지 않고, 다음처럼 쓰는 게 정확해.

애자일 팀은 *Product Owner*가 *risk*와 *control requirement*를 *backlog*도 관리하고 *Developers*가 구현·시험·모니터링한다. 팀의 권한은 초과하거나 중대한 *residual risk*가 존재하는 경우에는 조직에서 지정한 관리책임자 또는 *governance review* 체계도 *escalation*한다.

실제 애자일 역할 기반 운영모델

애자일 역할	Responsibility — 수행 업무	Accountability — 최종 책임
Product Owner	AI use case, intended use, stakeholder, 제품 요구사항, risk/control requirement를 Product Backlog에 반영하고 우선순위를 결정	제품 가치, 사용 범위, backlog 및 release 우선순위
Developers	모델·데이터·prompt·application·security control 구현, 테스트, monitoring instrumentation 및 gap 수정	Sprint Increment의 품질과 Definition of Done 충족
Scrum Master	AI GRC·Security·QE 검토가 workflow에 포함되도록 협업을 지원하고 impediment 제거	Scrum Team의 프로세스 효과성과 지속적 개선
QE/Tester ¹	Release Criteria를 test case도 변환하고 성능·안전·보안·회귀시험 수행	시험 범위와 test evidence의 신뢰성
Security/Privacy 담당자 ¹	Threat modeling, security/privacy requirement 정의 및 전문 검토	전문영역 검토 결과와 발견된 위험의 escalation
운영/MLOps 담당자 ¹	배포, logging, drift-failure monitoring, rollback과 incident response 수행	Production 운영 안정성과 monitoring evidence
AI GRC 담당자 ¹	Impact Assessment, use classification, 정책·규제 적용 여부 및 미충족 gap 검토	Governance review의 일관성과 미해결 중요 위험의 escalation
Business Sponsor /Management ²	중대한 residual risk와 예외를 검토하고 배포·계속 운영·중단 결정	조직이 수용하는 중대한 AI 위험에 대한 최종 의사결정

¹ 별도의 직책이 아니라 Developers에 포함된 전문 역량이거나 공유 지원조직일 수 있다.

² Scrum 역할은 아니지만 팀의 권한을 넘는 위험에 대한 조직적 의사결정 주체다.

Lifecycle별 현실적인 배정

Lifecycle	주 수행 역할	최종 판단
AI use case 식별	Product Owner	Product Owner
Impact Assessment	PO + Developers + Security/Privacy + AI GRC	Product Owner가 완결성을 확보
Sensitive-Restricted Use 분류	AI GRC + Legal/Security	조직 정책상 지정된 관리자
Release Criteria 정의	PO + Developers + QE	Product Owner
Pre-release Evaluation	Developers + QE	팀은 결과를 확인하고 PO가 release 판단
일반 Release	Product Owner + Developers	Product Owner
고위험·예외 Release	팀이 evidence 제출	Business Sponsor/Management
Deployment	Developers/MLOps	Developers가 Increment와 배포 품질 책임
Ongoing Monitoring	Developers/MLOps	Product Owner가 제품 대응 우선순위 결정
Gap Management	PO가 backlog화, Developers가 수정	PO가 우선순위, Developers가 구현 완료 책임
중대한 residual risk 수용	팀이 escalation	Business Sponsor/Management
중단	PO가 제안하거나 긴급 조치	권한 범위에 따라 PO 또는 Management

실무적인 핵심 구조

일반 gap은 애자일 안에서 처리할 수 있어.

Monitoring alert → Product Backlog 등록 → PO 우선순위 결정 → Developers 수정 → QE 검증 → 배포

하지만 다음과 같은 사안은 Scrum Team이 자체적으로 수용하면 안 돼.

- 법률·규제 위반 가능성
- 개인정보 또는 중요정보 유출
- Sensitive-Restricted Use 해당
- Responsible Release Criteria의 중대한 미충족
- 승인 우회나 안전 control 실패
- 대규모 고객·사용자 영향

이 경우에만 관리계층이나 공식 심의체계도 escalation해.